Monthly Intelligence Dispatch

October 2019

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specialises in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- By compromising the account of a senior manager at the Nuclear Power Corporation of India Limited (**NPCIL**), hackers managed to penetrate the infrastructure of the **Kudankulam** Nuclear Power Plant, where on October 19, 2019, the second power unit was shut down. Group-IB experts believe that the **Lazarus** group may be behind the events.
- Impostors posing as the Fancy Bear group demanded a ransom in Bitcoin from international banks, otherwise they threatened to launch a large-scale DDoS attack.
- NetTraveler, an APT group of Asian origin, attacked Russian government agencies in 2019. Traces of malicious programs were detected in at least two organizations in Russia.
- The RTM malware is being used to attack legal entities in Belarus.
- Group-IB's Threat Intelligence experts discovered a large database containing over 1.3 million records with credit and debit card data on Joker's Stash, an underground forum. More than 98% of them belong to the customers of Indian banks.
- Group-IB's analytical study helped the Dutch police take down the Moonwalk CDN, one of largest pirated video content providers in Russia and other post-Soviet countries. Moonwalk's closure had a knock-on effect, causing two large pirate CDNs, HDGO and Kodik, to experience problems in delivering video content.

Lazarus

In July 2019, threat actors penetrated the infrastructure of the Kudankulam Nuclear Power Plant (KKNPP), where in August 2019 the second power unit was commissioned. On October, 2019, the unit was shut down. Group-IB believes the incident may be linked to the successful compromise of the critical infrastructure at both the Nuclear Power Corporation of India Limited (NPCIL), a state-owned organization, and the **KKNPP**. The attacks involved a malware family called **TDrop2** or **Dtrack**. The malicious programs have similarities with the tools that the North Korean threat group Lazarus used in 2013 and 2015.

Fancy Bear

On October 23, banks in various countries started receiving emails from the Fancy Bear hacker group. In the emails, the group demanded a ransom in Bitcoin, otherwise they threatened to launch a large-scale DDoS attack. In some cases, the threat actors carried out a smaller-scale demonstration attack. Group-IB believes this campaign is not actually linked to Fancy Bear and was carried out by other threat actors posing as Fancy Bear with the aim of receiving ransoms.

NetTraveler

In 2019, an APT group of Asian origin attacked Russian government agencies: traces of malware were detected in at least two organizations, reports Positive Technologies. Russian organizations are periodically targeted by state-sponsored threat groups from various countries, including China. For instance, a notorious state-sponsored group called NetTraveler (aka Travnet, Netfile) mainly chooses targets for espionage purposes in the post-Soviet space, including Russia. Its victims include government agencies, oil industry, military contractors, and research centers and institutes. The group uses custom backdoors or publically available tools, which they distribute via spear-phishing emails with malicious attachments. Having gained access, the threat actors try to ensure persistence in their victim's network and collect data their government needs.

APT29

Cozy Bear is still active and has been attacking European ministries of foreign affairs. Researchers detected as many as three new malware families created by Cozy Bear, namely PolyglotDuke, RegDuke, and FatDuke as well as MiniDuke, a previously observed backdoor, which has been updated. The threat actors used these tools until very recently and the latest deployed sample was observed in June 2019. Experts dubbed this series of actions "Operation Ghost." Cozy Bear, which is a Russian-speaking hacking group also known as APT29 and Dukes, was very active between 2014 and 2017. At the time, the hackers were accused of hacking into the US Democratic National Committee in the run-up to the 2016 US election as well as of conducting numerous attacks against various government agencies within and outside Europe. Security experts believe the group allegedly works with the FSB (Russia's Federal Security Service) and has also been involved in the attacks on the US State Department, the US Joint Chiefs of Staff, and the email system of the White House.

Attor	Attor, a cyberespionage platform, has been spying on Russian-speaking users for the last seven years, ESET specialists report. The platform has a modular architecture and is designed to steal information. The experts believe that the attackers who use Attor target diplomatic missions and governmental institutions. The analysts found that Attor's command and control server (C&C) is located in the Tor network.
Simjacker	AdaptiveMobile Security specialists published a list of countries, where mobile operators provide users with SIM cards vulnerable to Simjacker attacks. Simjacker attacks, which the researchers described in September 2019, involve S@T Browser and SIM Toolkit (STK) instructions conveyed through SMS messages. Using a smartphone or a simple GSM modem, attackerы send a special SMS containing hidden SIM Toolkit instructions to the victim. These instructions are supported by the S@T Browser, which runs on the device's SIM card. The Simjacker vulnerability allows attackers to track users' devices. Other commands that the S@T Browser supports include setting up calls, sending messages, disabling the SIM card, running AT commands, opening browsers (with phishing links or by opening malicious webpages) and many others. This means that Simjacker attacks can be used not only to track users, but also to commit financial fraud, espionage (making a call and listening to conversations happening near the device), and sabotage (disabling the victim's SIM card) as well as to carry out misinformation campaigns (bulk SMS/MMS messaging with fake content) and so on.

EcoXyz

On September 4, the Chilean CSIRT published a report on the malicious activity against citizens and banks that involved the Proxy Changer technique and Chrome extensions. A malicious program was discovered that steals banking details from financial organizations. The malicious campaign involved a fake Flash Player plugin update that tried to infect targeted computers. Group-IB specialists observed and analyzed the malware sample used in the September campaign. The malware is a JS script designed to install a PAC file and a malicious Google Chrome extension on infected devices. Both actions are aimed at redirecting all visits to Chilean banks' websites to phishing pages by configuring a proxy server. We named this malware EcoXyz in our Threat Intelligence system.

Geost

Nearly 800,000 Russians fell victim to a banking botnet. Researchers at the Czech Technical University, the UNCUYO University, and Avast, a cybersecurity software company, studied an Android botnet called Geost. The researchers estimate that the Geost botnet has been active since 2016 and has infected over 800,000 Android devices. The discovery was made after the hackers decided to trust a malicious proxy network built using the HtBot malware. The proxy service can be rented to provide "secure" online communication between users. An analysis of HtBot communication led to the disclosure of a large operation that affected over 800,000 Android-based phones.

RTM

RTM, a malicious program developed by a hacker group with the same name, has been used in attacks on legal entities in Belarus. The Trojan, which is designed to target remote banking services and payment systems, was first discovered in 2015. Once attackers access a targeted system, they analyze information about how the victim organization works with banking apps or financial institutions' websites. They then log in to the system using remote access tools, and create a payment order to withdraw money. If the fraudsters are unable to carry out a transaction remotely, they steal authentication data and withdraw money using their own device. Since Q3 2018, the attackers have been sending out mass mail-outs containing RTM—several thousand emails daily. The malicious emails usually contain files disguised as official documents, e.g. "Оплата август-сентябрь" [Payment for August-September], "Копии документов" [Copies of documents], "Служебная записка" [Memo], "Отправка на четверг" [Sending on Thursday], "Реестр счетов" [Register of accounts], and "Сверка" [Reconciliation]. The email subjects and sender addresses constantly change. RTM mostly attacks banking customers in Russia. However, Group-IB researchers established that some versions of RTM also target banks in Belarus.

Diebold Nixdorf

In August 2019, new malware for Diebold Nixdorf ATMs was put up for sale on an underground forum. The tool exploits an RCE vulnerability when a Raspberry Pi device is connected to the Ethernet or USB ports of Opteva ATM models. An infection would most likely result in the dispensing of ATM cassettes (ATM jackpotting). The seller of the malware is a user named "Fear." In 2016, they sold a private banking Trojan called Midas bot (also known as Jupiter). In addition, a utility for Raspberry Pi devices called P4wnP1 has been publically available since February 2017. It is designed for attacks on Windows devices that involve connection through USB ports. The utility could potentially be used for attacks on ATMs.

Major events: ransomware

Ransomware	As many as ten healthcare facilities (three in the US state of Alabama and seven in Australia) were hit by ransomware attacks and had to either pause or switch off some of their systems, going into manual operation mode. All three affected US hospitals were closed to new patients as specialists coped with the attacks and recovered the systems. The Australian healthcare services suffered less: the ransomware attacks blocked hospitals' and other healthcare service providers' access to several systems, including financial management, patient registration, scheduling, appointment booking, and others. It is reported that all of the affected systems were shut down and isolated to prevent the malware from spreading further and the staff reverted to manual processes.
Demant	**Demant**, one of the biggest manufacturers of hearing aids, is expecting losses of up to $95 million due to a ransomware attack, which appears to be one of the biggest incidents of its kind, apart from the NotPetya ransomware outbreak known to have incurred companies like shipping giant Maersk and courier service FedEx losses of hundreds of millions of dollars. Demant's losses also outweigh the damage caused by a ransomware incident at the Norwegian aluminum giant Norsk Hydro, whose losses are estimated at $70 million. Demant started experiencing problems in early September, when in a short statement on its website the company said it was shutting down its entire internal IT infrastructure following what it initially described as "a critical incident."

Joker's Stash

Group-IB's Threat Intelligence experts discovered a large database with over 1.3 million records of credit and debit cards on **Joker's Stash**, an underground forum. More than 98% of the records belong to the customers of Indian banks. The database's price is estimated at more than $130 million—it is the biggest database of bank cards published as a single file. The monitoring of card shops revealed that a new database with compromised cards of Indian banks called "INDIA-MIX-NEW-01" appeared on Joker's Stash. The database contained over 550,000 dumps. On October 29, it was established that the full database contained 1,333,266 cards, with 1,323,036 of them (99%) belonging to Indian banks. On October 30, INDIA-MIX-NEW-01 was removed.

Sberbank

In October 2019, media outlets reported that some 60 million customer records of **Sberbank**, Russia's largest bank, had allegedly been put up for sale. Group-IB found that on September 28, a new user made posts on five different forums about selling an enormous banking database, which contained card numbers, full names, dates of birth, phone number, and other information. The seller offered a sample of 200 records and said the database was divided by regions and included major cities. This data does not allow fraudsters to steal money from bank accounts or cards, but can it be used for vishing and social engineering. In just six months in 2019, Russia's Central Bank discovered 13,000 posts about selling and buying personal data, but only 1,500 of them were databases of financial organizations.

Major events: attacks on banks and their customers

Sochi Marriott

Group-IB discovered an active network of websites that copied those of popular hotels in Sochi, Russia. A graph analysis conducted using Group-IB's Brand Protection system revealed about 60 suspicious websites that mentioned well-known brands, such as **Marriott Krasnaya Polyana**, the **Roza Khutor** ski resort, the **Gorki Plaza** hotel, and others. The creators of the clone websites copy the design of the official resources, use their logos, brands, and brand colors. Room prices per night on the fake websites range from $117 to $1,480. This poses risks because apart from resellers, clone websites are actively used by fraudsters for the purposes of stealing money or bank card data. Clone websites are one of the most popular methods of online fraud, since creating them does not require any special skills or substantial investment: $1,500–$4,600 is an average revenue from these websites, with the costs of creating them averaging $1–$8.

eGobbler

Fraudsters used a browser bug to show billions of ads. The hacking group eGobbler exploited a vulnerably in Chrome for iOS as well as the desktop versions of Chrome and Safari to bypass security systems and show their victims pop-up ads and redirect them to malicious websites. Security specialists first observed eGobbler in the fall of 2018 and the group is still one of the most serious threats when it comes to malicious ads. The threat actors are usually active for a short time during major holidays. For instance, in February 2019, on Washington's Birthday, a federal holiday in the United States, the hackers showed US users over 800 million malicious ads, which redirected victims to fake technical support websites and phishing resources.

Arrests and sentences

CDN

In February 2019, Group-IB published a post on TorrentFreak, a BitTorrent news website, describing where the biggest content delivery network (CDN) called Moonwalk was located, how big it was, how it was monetized, and how easy it was to create a pirate website using it. This was noticed by the Dutch police and the anti-piracy groups MPAA, ACE, and BREIN. They determined what servers had to be seized in order to shut down the service. The closure of the Moonwalk CDN, one of the biggest pirated content providers in Russia and other post-Soviet countries, had a knock-on effect: two other large pirate CDNs, HDGO and Kodik, which used some of Moonwalk's servers in the Netherlands and had an "exchange agreement" with it, started experiencing problems in delivering video content. The entire pirate CDN "Big Three"—Moonwalk, HDGO, and Kodik—collapsed. Moonwalk aggregated 42,807 movies (with 14,549 of them being TV series). Kodik lost almost a half of its content (8,000 out of 17,000 TV shows), while HDGO had a database of over 25,000 items (60% films and 40% TV series) at the time of its shutdown. Group-IB estimates that up to 90% of Russian pirate streaming services have been affected by the fall of Moonwalk, HDGO, and Kodik. While the cost of monthly maintenance of a large CDN infrastructure was about $100,000, the revenues were in the millions, which means the now vacant niche might be occupied by new players very soon.

Arrests and sentences

CyberBunker 2.0

The German police shut down CyberBunker 2.0, a criminal hosting business located in a Cold War–era bunker in Rhineland-Palatinate, a state in Germany. The investigators reported that they had seized about 200 servers that operated throughout the closely guarded facility and arrested seven people as part of a large-scale police operation. The servers in CyberBunker 2.0 hosted drug-dealing resources, fraudulent and illegal trade platforms, and child porn websites. The police found that the attack on Deutsche Telekom routers, which affected about 900,000 customers, was controlled via a server located in that facility. At the moment, 13 people are under investigation, three of them German citizens and seven—Dutch nationals. During the raid, the police also seized about $41 million in cash and numerous mobile phones and data carriers.

Ho Jun Jia

A citizen of Singapore is facing 30 years in prison for identity theft and cryptocurrency mining using Amazon Web Services (AWS). The US Department of Justice brought charges against Ho Jun Jia, a 29-year-old Singaporean, who illegally mined cryptocurrencies using a stolen identity. According to the judicial documents, Ho stole the identity of a prominent California game developer (including their name, driver's license, and credit card data) to open cloud computing accounts at multiple cloud service providers, including AWS and Google Cloud. Ho is also said to have used the identities of a Texas resident and the founder of a tech company in India.

Forecasts and warnings

- According to our data, the main interest in the energy sector is coming from APT groups that researchers link to Iran, Russia, and North Korea. We forecast that supply chain attacks will become threat actors' main attack vector. Management companies will be attacked first and used as a stepping stone to get to energy companies. In most such cases, hackers conduct espionage, but there have been attacks that resulted in critical infrastructures being shutdown.
- We forecast an increasing number of fake airline and hotel websites. The campaign that promotes these resources is active not only in high season, but also during Christmas and New Year holidays, when prices for stays at prestigious resorts grow twofold at the least.
- The closure of the "Big Three" of pirate CDN services, which supplied resources in Russia and other post-Soviet countries with illegal video content, has led to the restructuring of the market and the rise of aggregators and small CDNs, who are trying to occupy the now vacant niche.

If you wish to receive more detailed information about a specific incident, threat or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organisation.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com